
ISO/IEC 27706:2025

Plain-Language Guide for the Organization Seeking PIMS Certification

What your PIMS certification body must do, and what that means for you

What each requirement means, why it exists, what it means for you, what to have ready, what to record, and how to report it.

Coverage

How 27706 fits with ISO/IEC 17021-1 and ISO/IEC 27701.
Competence requirements for PIMS auditors and decision-makers.
Impartiality and governance in the privacy market.
Scope, audit duration, and conducting the PIMS audit.

Audience

Privacy and compliance managers, DPOs, and anyone preparing for or holding PIMS certification who wants to know what to expect from the certification body.

Before You Use This Document

This is a companion guide, not a copy of the standard.

ISO/IEC 27706:2025 is a copyrighted publication of ISO and IEC. Nothing in this document reproduces the text of the standard. Every requirement here is described in original wording. If you need to rely on exact wording, obtain a licensed copy. Where this guide and the standard appear to differ, the standard governs.

A note on the anchors. Entries in this guide are anchored at *clause family* level – Clause 5, Clause 7, Clause 9 – rather than at precise sub-clause numbers. That is deliberate. The standard’s clause structure, its scope, and its substantive additions over the technical specification it replaced are matters of public record and are described accurately here. Its internal sub-clause numbering is not, and inventing precise references would give this guide a false appearance of precision. Read alongside a licensed copy if you need to cite a specific provision.

Two structural notes. First, ISO/IEC 27706 is written for certification bodies: they are required to conform to it, and their accreditation body audits them against it. You are not required to comply with it. This guide reads it from the other side of the table. Second, 27706 operates *in addition to* ISO/IEC 17021-1, so this guide does not repeat what the companion guide to that standard covers. The general certification requirements, the process from application to recertification, and the appeals machinery all still apply in full.

What this guide does

It takes each requirement in ISO/IEC 27706:2025 and answers six questions about it, in the same order every time:

1. **What the clause requires.** What your certification body must do, in ordinary language, with no assumed background.
2. **Why it exists.** The failure it prevents, and why the certification body behaves as it does. A great deal of what feels arbitrary during an audit follows directly from one of these.
3. **What this means for you.** The practical consequence for the organization being certified: what to expect, what to prepare, what you are entitled to ask for, and where your own obligations sit.
4. **Evidence to collect.** Named artifacts, on your side of the relationship. Not “documentation” but the actual thing to have on file.
5. **How to document it.** What to record, whether you are running an internal review of your certification arrangements or preparing to challenge something.
6. **Executive summary treatment.** Suggested language where the position is unsatisfactory, written for an audience that does not read clause numbers.

On vocabulary

Technical terms are defined the first time they appear, shown like **this**, and collected in the glossary. If you hit a term that is not defined, that is a defect in this document; note it and it will be fixed in the next revision.

Navigating this document

Each part opens with a quick-reference table. Every reference number and title in those tables is a live link to the full entry, so the tables work as a jump menu rather than just a contents list. Entries also appear in the PDF bookmark panel, and the index at the back links back into the text.

Link colour carries meaning. Here it marks whether a clause is something you can *act on*:

Orange, marked cvb

Actionable from your side: a right you can exercise, an obligation on the certification body you can hold it to, or an obligation on *you* that you can breach. This is where to look when something goes wrong, or when you want to know what you are entitled to.

Blue

Internal certification body governance. Real, and assessed by the accreditation body, but not something you interact with directly. Context that makes the rest legible.

Twenty-four of the twenty-six entries are orange, an even higher proportion than in the companion guide to ISO/IEC 17021-1, and for the same reason amplified. Read from the certification body's side this standard is internal governance. Read from yours, almost everything in it either shapes what you will experience or creates an obligation you can breach.

The marker letters are printed as well as coloured, so the distinction survives greyscale printing and does not depend on colour vision. The classification is a judgment, not something the standard states; it is held in a single file in the source and can be re-scoped without touching any content.

One entry, one page

Every clause and control begins at the top of a fresh page and is complete before the next one starts. This wastes some paper and makes the document longer than it needs to be. It also means you can print a single control and hand it to the person who owns it, which is what these documents actually get used for.

How this guide is organized

The first chapter covers how 27706 fits: what it is, what it sits on top of, what is actually being certified, and the controller and processor distinction that organizes everything else.

The three chapters that follow cover the substantive additions 27706 makes over the technical specification it replaced. Competence, under Clause 7, covering PIMS auditors, technical experts, and certification decision-makers. Impartiality and governance, under Clauses 5 and 6. Then scope determination, audit duration, and the conduct of the audit itself under Clause 9, including the three structured evaluations the standard requires.

What this guide does *not* cover is everything ISO/IEC 17021-1 already provides: the general principles, the certification process from application through recertification, the right to object to an audit team member, and the appeals and complaints machinery. Those apply in full to PIMS certification and are covered in the companion guide.

Five things that catch people out

Check the accreditation scope says PIMS. Accreditation for ISMS certification does not extend to PIMS certification. A body may be genuinely accredited and still be outside its scope when it issues your privacy certificate, and the certificate will look identical either way. This is the single quickest check in this guide.

Do not copy your ISMS scope. ISO/IEC 27701:2025 is standalone, so PIMS scope is established in its own right. A copied scope is usually wrong in both directions: it includes functions processing no personally identifiable information, and excludes processing outside the ISMS boundary. Derive it from where PII is actually processed.

Budget audit time on its own criteria. Organizations coming from the integrated model expect PIMS time to be a small increment on ISMS time. Under standalone duration criteria tailored to controller and processor roles, it can be materially larger. Find out before contracting rather than during planning.

Privacy risk is not security risk with different labels. Security risk asks what harm a breach does to the organization. Privacy risk includes harm to the individual, which can be substantial where organizational impact is negligible. A risk register counting only organizational impact has not assessed privacy risk, and 27706 now requires structured evaluation of exactly this.

Your audit evidence may itself be personal data. Demonstrating conformity often means showing records, rights requests, and incident detail. The certification body's confidentiality obligation protects that once disclosed; it does not make the disclosure lawful. That part is yours, and handing over unredacted personal data without considering the basis is a visible inconsistency in an organization certifying its privacy management.

Three definitions you need before anything else

Controller and processor

The two roles around which 27706 tailors its scope and duration criteria. A controller determines the purposes and means of processing; a processor acts on a controller's behalf. Determination follows the factual reality of who decides, not the contractual label, and many organizations are both. The role drives scope, audit time, the competence your audit team needs, and what appears on your certificate.

The three-standard relationship

ISO/IEC 27701 is what you implement and are certified against. ISO/IEC 17021-1 governs how any management system certification body operates. ISO/IEC 27706 adds what is specific to certifying a PIMS. You conform to the first; your certification body conforms to the other two. When a body asks for something, establishing which document it comes from tells you whether it is a requirement on your system or on their process.

Structured evaluation

The requirement 27706 adds for assessment of privacy risk management, leadership, and performance monitoring. It raises the bar from confirming that documentary artefacts exist to establishing that the thing itself is working, which is why top management should expect to be interviewed and to need to speak credibly about privacy without preparation.

How to read the executive summary sections

Every entry ends with suggested reporting language. It is deliberately written to avoid three habits that get security findings ignored: control numbers in the first sentence, adjectives about maturity, and recommendations that amount to “do it better.” Each one names a specific consequence and, where possible, attaches a number. Adapt the wording; keep the structure.

Contents

Before You Use This Document	ii
1 Foundations: How 27706 Fits	1
What 27706 is What ISO/IEC 27706 is, and what it sits on top of	2
Relationship to 17021-1 What carries over from ISO/IEC 17021-1	3
Relationship to 27701 What is actually being certified: the PIMS under ISO/IEC 27701	4
Controller and processor Controller and processor: the distinction that organizes everything	5
PIMS scope Determining PIMS scope, and how it relates to any ISMS scope	6
Transition The transition from ISO/IEC TS 27006-2:2021	7
2 Competence: Clause 7	8
Cl. 7 – framework The competence framework for PIMS certification	9
Cl. 7 – privacy law Knowledge of privacy law and regulation	10
Cl. 7 – role competence Competence for the controller and processor roles	11
Cl. 7 – technical experts Technical experts in a privacy context	12
Cl. 7 – decision-makers Competence of certification decision-makers	13
3 Impartiality and Governance: Clauses 5 and 6	14
Cl. 5 – impartiality Strengthened impartiality expectations for PIMS certification	15
Cl. 5 – outsourced DPO Where your certification body also supplies privacy services	16
Cl. 5 – confidentiality of PII Confidentiality where the audit evidence is personal data	17
Cl. 6 – governance Governance expectations for PIMS certification bodies	18
4 Scope and Audit Duration: Clause 9	19
Cl. 9 – scope criteria Scope determination criteria for a PIMS	20
Cl. 9 – audit time Audit duration criteria for a PIMS	21
Cl. 9 – combined audits Combining PIMS certification with other management systems	22
Cl. 9 – multi-jurisdiction Multi-site and multi-jurisdiction PIMS certification	23
5 Conducting the PIMS Audit: Clause 9	24
Cl. 9 – privacy risk Structured evaluation of privacy risk management	25
Cl. 9 – leadership Structured evaluation of leadership	26
Cl. 9 – performance Structured evaluation of performance monitoring	27
Cl. 9 – stage 1 Stage 1 in a PIMS context	28
Cl. 9 – stage 2 Stage 2 in a PIMS context	29
Cl. 9 – certificate What your PIMS certificate must convey	30
Cl. 9 – maintaining Surveillance, change, and maintaining PIMS certification	31
Glossary	32
Index of Terms and Concepts	34

CHAPTER 1

Foundations: How 27706 Fits

Six entries establishing how ISO/IEC 27706 fits with the two standards either side of it. Three documents are in play and confusing them wastes effort: ISO/IEC 27701 is what your organization implements and is certified against, ISO/IEC 17021-1 governs how any management system certification body operates, and 27706 adds what is specific to certifying a PIMS.

You conform to the first. Your certification body conforms to the other two. When a body asks you for something, establishing which document the request comes from tells you whether it is a requirement on your management system or on their process, and organizations routinely implement things they do not need because that distinction was never drawn.

Two determinations in this chapter shape everything downstream: the controller and processor roles within your scope, and the PIMS scope itself. Both are commonly settled by copying something that already exists – a contractual label, or an existing ISMS scope – and both are usually wrong when settled that way.

Quick reference: foundations

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **cyb** or **ai** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
What 27706 is cyb	What ISO/IEC 27706 is, and what it sits on top of	Certification body accreditation certificate showing PIMS scope
Relationship to 17021-1 cyb	What carries over from ISO/IEC 17021-1	Your certification agreement, which will reference both standards
Relationship to 27701 cyb	What is actually being certified: the PIMS under ISO/IEC 27701	Your PIMS documentation mapped to ISO/IEC 27701 requirements
Controller and processor cyb	Controller and processor: the distinction that organizes everything	Role determination across processing activities
PIMS scope cyb	Determining PIMS scope, and how it relates to any ISMS scope	PIMS scope statement and its derivation
Transition cyb	The transition from ISO/IEC TS 27006-2:2021	Your 27701 transition plan with dates

What 27706 is What ISO/IEC 27706 is, and what it sits on top of

WHAT THE CLAUSE REQUIRES

ISO/IEC 27706:2025 specifies requirements, and provides guidance, for bodies that audit and certify a privacy information management system against ISO/IEC 27701. It operates in addition to ISO/IEC 17021-1 rather than instead of it: a body certifying a PIMS must satisfy both. The requirements concern the competence and reliability of PIMS certification bodies, and the guidance supplies additional interpretation of them. The document can be used as a criteria document for accreditation, peer assessment, or other audit processes.

WHY IT EXISTS

Three standards are in play and confusing them wastes effort. ISO/IEC 27701 is what your organization implements and is certified against. ISO/IEC 17021-1 governs how any management system certification body must operate. ISO/IEC 27706 adds what is specific to certifying a PIMS. You conform to 27701; your certification body conforms to the other two.

WHAT THIS MEANS FOR YOU

1. Confirm your certification body's accreditation covers PIMS certification specifically, not management system certification generally.
2. Understand that 27706 obligations fall on the body, not on you, but shape what you will experience.
3. Read this guide alongside its companion on 17021-1, since the general requirements are not repeated here.
4. Where a body cannot demonstrate it works to 27706, question whether its PIMS certificates carry accredited status.

EVIDENCE TO COLLECT

- Certification body accreditation certificate showing PIMS scope
- The accreditation body's published scope for that certification body

HOW TO DOCUMENT IT

Record whether the certification body's accreditation explicitly covers PIMS certification against ISO/IEC 27701. Accreditation for ISMS certification does not extend to PIMS, and a certificate issued outside the accredited scope is not an accredited certificate.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the PIMS certificate was issued by a body whose accreditation covers information security management system certification but not privacy information management system certification, so the certificate does not carry the accredited status it is presented as having.

Relationship to 17021-1 What carries over from ISO/IEC 17021-1

WHAT THE CLAUSE REQUIRES

27706 aligns its clause structure to ISO/IEC 17021-1, which is a change from the technical specification it replaced. Everything in 17021-1 continues to apply in full: the principles of impartiality, competence, responsibility, openness, confidentiality, responsiveness to complaints, and risk-based approach; the requirements on legal and contractual arrangements, structure, resources, and information; the whole certification process from application through recertification; and the appeals and complaints machinery. 27706 adds privacy-specific requirements at the corresponding clauses.

WHY IT EXISTS

The alignment matters practically because it means you can read the two documents against each other clause by clause. It also means every right you have under 17021-1 you also have here: the right to object to a proposed audit team member, the right to appeal a certification decision without discriminatory consequence, the entitlement to a competent team. None of that is diminished because the subject is privacy.

WHAT THIS MEANS FOR YOU

1. Treat your rights under 17021-1 as fully available in a PIMS certification context.
2. Where a certification body cites 27706 as a reason for something, check whether 17021-1 already governs the point.
3. Use the same appeals and complaints routes; 27706 does not create separate ones.
4. Expect the general certification process to look familiar, with privacy-specific additions layered on.

EVIDENCE TO COLLECT

- Your certification agreement, which will reference both standards
- The certification body's published process information

HOW TO DOCUMENT IT

Record whether the organization understands that its 17021-1 rights apply here. Organizations approaching PIMS certification as an unfamiliar process sometimes accept treatment they would challenge in an ISMS audit.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has accepted certification body decisions in the PIMS context that it would have challenged under its established ISMS certification arrangements, without recognising that the same rights apply.

Relationship to 27701 What is actually being certified: the PIMS under ISO/IEC 27701**WHAT THE CLAUSE REQUIRES**

The subject of certification is a privacy information management system implemented in accordance with ISO/IEC 27701. The 2025 edition of 27701 is a standalone standard following the same Clauses 4 to 10 structure as other management system standards, with annexed controls organized around the controller and processor roles together with a set of security controls. 27706 governs how a certification body assesses conformity with that standard; it does not add requirements to the PIMS itself.

WHY IT EXISTS

This division matters when a certification body asks for something. If the request traces to 27701, it is a requirement on your PIMS and you must satisfy it. If it traces to 27706, it is a requirement on the body's process and your role is to enable it rather than to conform to it. Organizations sometimes implement things they do not need because the distinction was never made clear.

WHAT THIS MEANS FOR YOU

1. When a certification body makes a request, establish whether it derives from 27701 or from its own obligations under 27706.
2. Do not implement PIMS elements that exist only to serve the certification body's process.
3. Ensure your PIMS is built to 27701 rather than to an auditor's preferences.
4. Where the 2025 edition changed the PIMS structure, confirm your system reflects the current edition.

EVIDENCE TO COLLECT

- Your PIMS documentation mapped to ISO/IEC 27701 requirements
- Certification body requests with their basis identified

HOW TO DOCUMENT IT

Record any PIMS element implemented solely at a certification body's request without a traceable 27701 requirement. These represent cost carried for no conformity benefit.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has implemented PIMS elements at the certification body's request that trace to no requirement in ISO/IEC 27701, carrying ongoing cost with no effect on conformity.

Controller and processor Controller and processor: the distinction that organizes everything

WHAT THE CLAUSE REQUIRES

27706 provides audit duration and scope determination criteria tailored to the controller and processor roles. The distinction runs through PIMS certification because the obligations differ substantially: a controller determines the purposes and means of processing personally identifiable information, while a processor processes on a controller's behalf. An organization may act in both roles for different processing, and the certification must reflect which roles are within scope.

WHY IT EXISTS

Role determination affects scope, audit time, competence requirements for your audit team, and what appears on your certificate. Getting it wrong produces a certificate that does not describe what you actually do, which is a problem when a customer relies on it. Organizations acting in both roles frequently present themselves as one, usually as a processor, because the obligations feel lighter.

WHAT THIS MEANS FOR YOU

1. Determine your roles honestly across all processing in scope, since many organizations are both.
2. Expect audit time and scope to differ according to role, and expect a dual-role organization to attract more of both.
3. Check that your certificate states the roles it covers.
4. Verify the role determination follows the factual reality of who decides purposes and means, not the contractual label.

EVIDENCE TO COLLECT

- Role determination across processing activities
- Scope statement showing roles covered
- Contracts for comparison against factual role

HOW TO DOCUMENT IT

Record whether the role determination reflects factual decision-making or contractual labelling. An organization certified as a processor that in fact determines purposes for some processing holds a certificate that misdescribes it.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization is certified in the processor role while determining the purposes and means of processing for a stated set of activities, so it is acting as a controller for processing the certificate does not cover in that capacity.

PIMS scope Determining PIMS scope, and how it relates to any ISMS scope**WHAT THE CLAUSE REQUIRES**

27706 provides scope determination criteria for PIMS certification. Because the 2025 edition of ISO/IEC 27701 is standalone rather than requiring ISO/IEC 27001 as a prerequisite, the PIMS scope is established in its own right. Where an organization also holds ISMS certification, the two scopes are determined separately and may differ, and the relationship between them has to be established rather than assumed.

WHY IT EXISTS

This is the trap for organizations coming from the integrated model of the previous edition. A PIMS scope drawn by copying the ISMS scope will frequently be wrong in both directions: it may include functions that process no personally identifiable information, and it may exclude processing that sits outside the ISMS boundary. Customers reading the PIMS certificate care about where their data is handled, not about where information security controls are applied.

WHAT THIS MEANS FOR YOU

1. Determine PIMS scope from where personally identifiable information is actually processed, not by copying the ISMS scope.
2. Where both certifications exist, document the relationship between the two scopes explicitly.
3. Check for PII processing outside the ISMS boundary that must nonetheless be in the PIMS scope.
4. Verify the scope statement will mean something to a customer assessing whether their data is covered.

EVIDENCE TO COLLECT

- PIMS scope statement and its derivation
- ISMS scope statement for comparison
- PII processing inventory against both scopes

HOW TO DOCUMENT IT

Compare the PIMS scope against an independently compiled inventory of where personally identifiable information is processed. Processing outside the scope is uncertified regardless of how comprehensive the scope statement sounds.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the PIMS scope was derived from the existing ISMS scope rather than from where personally identifiable information is actually processed, and a stated number of processing activities fall outside it, so they carry no PIMS certification.

Transition The transition from ISO/IEC TS 27006-2:2021

WHAT THE CLAUSE REQUIRES

27706 is a full International Standard replacing the earlier technical specification ISO/IEC TS 27006-2:2021, and it brings the certification infrastructure for ISO/IEC 27701 up to date alongside the 2025 edition of that standard. Compared with the technical specification, it establishes a dedicated framework for bodies certifying against ISO/IEC 27701:2025, introduces defined competence requirements for PIMS auditors, technical experts, and certification decision-makers, strengthens impartiality and governance expectations, requires structured evaluation of privacy risk management, leadership, and performance monitoring, and supplies audit duration and scope determination criteria tailored to the controller and processor roles. Accreditation bodies have published transition arrangements.

WHY IT EXISTS

Two transitions are running at once: your PIMS moves to the 2025 edition of 27701, and your certification body moves to 27706. They interact, because your recertification will be conducted by a body working to new rules against a standard you have newly transitioned to. Organizations that plan only their own transition are surprised by the effect of the body's.

WHAT THIS MEANS FOR YOU

1. Establish both transition timelines: yours to ISO/IEC 27701:2025, and your certification body's to 27706.
2. Ask your certification body when it expects to be assessed against 27706 and what changes for you.
3. Check your accreditation body's published transition arrangements for applicable deadlines.
4. Expect audit time and scope determination to be recalculated under the new criteria.

EVIDENCE TO COLLECT

- Your 27701 transition plan with dates
- Certification body's 27706 readiness position
- Accreditation body transition arrangements

HOW TO DOCUMENT IT

Record both transition timelines and whether they are aligned. A certification body not yet assessed against 27706 cannot issue certification reflecting the new criteria, which may matter for the status of certificates issued in the interim.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has planned its transition to ISO/IEC 27701:2025 without establishing whether its certification body will be assessed against ISO/IEC 27706 in time to certify against it, creating a risk of delayed or interim-status certification.

Competence: Clause 7

Five entries on the competence requirements 27706 introduces for PIMS auditors, technical experts, and certification decision-makers. This is one of the main additions over the technical specification 27706 replaced.

Competence is treated more rigorously here than for a general management system because privacy conformity depends on legal judgment in a way information security largely does not. An auditor can assess whether encryption is applied without knowing much law. Assessing whether a lawful basis is correctly identified, or whether a role determination is right, requires knowing the law that governs it.

The signal to watch for is a certification body that has extended into PIMS work from an information security base and reassigned existing auditors without demonstrable privacy competence. You will notice it in the findings: an audit that produces only documentation findings and never engages with the applicable legal regime has probably not assessed privacy conformity in substance. Competence is a legitimate ground for objecting to a proposed team member under ISO/IEC 17021-1, and that right applies here.

Quick reference: Competence (Cl. 7)

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [cyb](#) or [ai](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
Cl. 7 – framework cyb	The competence framework for PIMS certification	Certification body's stated competence criteria for PIMS roles
Cl. 7 – privacy law cyb	Knowledge of privacy law and regulation	Applicable privacy regimes for your processing
Cl. 7 – role competence cyb	Competence for the controller and processor roles	Roles within certification scope
Cl. 7 – technical experts cyb	Technical experts in a privacy context	Technical expert involvement and subject matter
Cl. 7 – decision-makers	Competence of certification decision-makers	Certification decision record

Cl. 7 – framework The competence framework for PIMS certification

WHAT THE CLAUSE REQUIRES

27706 introduces defined competence requirements for the people involved in PIMS certification, covering auditors, technical experts, and the personnel who take certification decisions. Competence is specified for the functions each performs, and the certification body must be able to demonstrate that the individuals assigned to your certification meet the requirements for their role. This is an addition over the technical specification 27706 replaced, where competence expectations were less fully defined.

WHY IT EXISTS

The reason competence is treated more rigorously for PIMS than for a general management system is that privacy conformity depends on legal judgment in a way information security largely does not. An auditor can assess whether encryption is applied without knowing much law. Assessing whether a lawful basis is correctly identified, or whether a role determination is right, requires knowing the law that governs it.

WHAT THIS MEANS FOR YOU

1. Ask what competence the certification body requires of PIMS auditors, and how it evidences that the assigned team meets it.
2. Confirm competence is assessed for your specific assignment rather than held generically at the body level.
3. Remember that competence requirements reach the certification decision-maker, not only the audit team.
4. Object on competence grounds where the proposed team clearly lacks privacy capability; this is a legitimate ground under 17021-1.

EVIDENCE TO COLLECT

- Certification body's stated competence criteria for PIMS roles
- Team composition for your audit with stated competence
- Any competence objection raised and its resolution

HOW TO DOCUMENT IT

Record whether competence was evidenced for the specific individuals assigned rather than asserted at organizational level. Bodies transitioning from ISMS certification into PIMS work sometimes reassign existing auditors without demonstrable privacy competence.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the audit team assigned to the PIMS certification comprises information security auditors with no evidenced privacy competence, so the assessment of privacy-specific requirements rests on capability the certification body has not demonstrated.

Cl. 7 – privacy law Knowledge of privacy law and regulation

WHAT THE CLAUSE REQUIRES

PIMS auditor competence includes knowledge of the privacy legislation and regulation applicable to the organization being audited and to the processing within scope. Because privacy law is jurisdictional and the applicable regime depends on where personally identifiable information originates, where it is processed, and who the individuals are, this competence is specific to your circumstances rather than general.

WHY IT EXISTS

A PIMS operates against a legal backdrop, and an auditor who does not know the applicable regime cannot assess whether the system addresses it. This is the competence dimension most likely to be missing where a certification body has extended into PIMS work from an information security base, and it is the one you will notice, because findings will engage with documentation rather than with obligations.

WHAT THIS MEANS FOR YOU

1. Establish which privacy regimes apply to your processing and confirm the audit team knows them.
2. Where you operate across jurisdictions, ask how the body covers regimes outside its home territory.
3. Expect the team to engage with your lawful bases and role determinations, not only your procedures.
4. Treat an audit that never touches applicable law as a competence signal worth raising.

EVIDENCE TO COLLECT

- Applicable privacy regimes for your processing
- Audit team competence for those regimes
- Findings evidencing engagement with legal requirements

HOW TO DOCUMENT IT

Record whether findings engaged with the applicable legal regime or only with the presence of documentation. A PIMS audit producing only documentation findings has probably not assessed the substance of privacy conformity.

EXECUTIVE SUMMARY TREATMENT

Suggested language: PIMS audit findings across the cycle address documentation and procedure exclusively, with no engagement with the privacy legislation applicable to the organization's processing, indicating the audit did not assess legal conformity in substance.

Cl. 7 – role competence Competence for the controller and processor roles**WHAT THE CLAUSE REQUIRES**

Because 27706 tailors its criteria to the controller and processor roles, competence expectations follow that split. Assessing a controller's PIMS requires understanding obligations around purpose determination, lawful basis, transparency, and individual rights. Assessing a processor's PIMS requires understanding obligations that arise from acting on a controller's instructions, including the boundaries of those instructions and the sub-processing chain.

WHY IT EXISTS

These are genuinely different assessment problems. A processor audit turns substantially on whether the organization stays within instructions and manages its sub-processors; a controller audit turns on whether the processing has a proper basis and individuals can exercise rights. An auditor competent in one is not automatically competent in the other, and an organization acting in both roles needs a team covering both.

WHAT THIS MEANS FOR YOU

1. Confirm the audit team's competence matches the roles within your scope, particularly if you act in both.
2. Where you are a processor, expect scrutiny of instruction boundaries and the sub-processing chain.
3. Where you are a controller, expect scrutiny of lawful basis, transparency, and rights handling.
4. Where you are both, verify the team covers both rather than defaulting to one.

EVIDENCE TO COLLECT

- Roles within certification scope
- Audit team competence mapped to those roles
- Audit coverage of role-specific obligations

HOW TO DOCUMENT IT

Record whether audit coverage matched the roles in scope. A dual-role organization audited only against processor obligations has had half its PIMS assessed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization acts as both controller and processor within the certified scope, but the audit addressed only processor obligations, so controller-role conformity was not assessed.

Cl. 7 – technical experts Technical experts in a privacy context

WHAT THE CLAUSE REQUIRES

27706 defines competence requirements for technical experts as well as auditors. A technical expert supplies specific knowledge or expertise on the subject being audited and accompanies the audit team rather than auditing independently. In a PIMS context this may cover a particular legal regime, a specialised processing technology, or a sector where privacy obligations are unusual.

WHY IT EXISTS

Technical experts are how a certification body covers competence it does not hold in its core team, and their use is legitimate and often desirable. What matters to you is that the expert's presence does not change who is accountable: the audit team conducts the audit and the certification body remains responsible. It also matters that the expert is bound by the same confidentiality obligations, which is particularly significant when the subject is personally identifiable information.

WHAT THIS MEANS FOR YOU

1. Where your context is specialised, ask whether a technical expert will be used and for what.
2. Confirm technical experts are bound by confidentiality obligations equivalent to the audit team's.
3. Understand that the expert advises; the auditors audit and the body decides.
4. Where no expert is used but your context clearly requires one, raise it.

EVIDENCE TO COLLECT

- Technical expert involvement and subject matter
- Confidentiality coverage for technical experts

HOW TO DOCUMENT IT

Record whether technical experts attending the audit are covered by confidentiality obligations. This matters more here than in most audits because what they will see is personally identifiable information.

EXECUTIVE SUMMARY TREATMENT

Suggested language: technical experts attending the PIMS audit and accessing personally identifiable information are not demonstrably bound by confidentiality obligations equivalent to those covering the certification body's own personnel.

Cl. 7 – decision-makers Competence of certification decision-makers**WHAT THE CLAUSE REQUIRES**

27706 extends defined competence requirements to the personnel who take PIMS certification decisions. Under ISO/IEC 17021-1 these people must not have participated in the audit, so they decide on the basis of the audit information rather than direct observation. 27706 requires that they hold competence appropriate to PIMS certification decisions.

WHY IT EXISTS

This closes a gap that would otherwise undermine everything else. A competent privacy audit team producing a sound report achieves nothing if the person deciding cannot evaluate what it says. Because the decision-maker did not attend the audit, their competence is what allows them to interpret the report correctly, and to identify where it is thin.

WHAT THIS MEANS FOR YOU

1. Understand that the decision on your certification is taken by someone who did not audit you and must be competent to take it.
2. Where a decision appears inconsistent with the audit findings, this is a legitimate matter to appeal.
3. Expect the decision-maker to request further information where the report is insufficient; this is the competence working.
4. Do not treat audit team comments as a decision, since it is not theirs to take.

EVIDENCE TO COLLECT

- Certification decision record
- Evidence of decision-maker independence from the audit team

HOW TO DOCUMENT IT

Record whether the certification decision engaged with the audit findings or simply ratified them. A decision function that has never requested further information or diverged from an audit recommendation may not be exercising independent judgment.

EXECUTIVE SUMMARY TREATMENT

Suggested language: certification decisions ratify audit recommendations without recorded independent consideration, so the separation between audit and decision that the standards require is procedural rather than substantive.

Impartiality and Governance: Clauses 5 and 6

Four entries on the strengthened impartiality, independence, and governance expectations 27706 places on bodies conducting PIMS audits.

The privacy market has a structural feature that makes this bite more often than its equivalent in information security: many firms offer privacy consultancy, outsourced data protection officer services, privacy assessments, and certification, and the same corporate groups frequently supply several of these. An organization that engaged a firm for privacy advice and then approached it for certification is in a common situation, not an unusual one. Map every privacy service you receive and from whom, including through group entities, and disclose early rather than discovering late.

One issue in this chapter has no counterpart in a general certification audit. PIMS audit evidence frequently is personally identifiable information, because demonstrating conformity may require showing records, rights request handling, and incident detail. The certification body's confidentiality obligation protects that information once disclosed, but it does not make the disclosure lawful. That part is yours, and an organization certifying its privacy management while handing over unredacted personal data without considering the basis has a visible inconsistency.

Quick reference: Impartiality (Cl. 5-6)

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **cyb** or **ai** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
Cl. 5 – impartiality_{cyb}	Strengthened impartiality expectations for PIMS certification	Your privacy advisory supplier relationships including group structures
Cl. 5 – outsourced DPO_{cyb}	Where your certification body also supplies privacy services	Privacy service supplier map including group relationships
Cl. 5 – confidentiality of PII_{cyb}	Confidentiality where the audit evidence is personal data	Evidence provision approach with redaction or minimisation where possible
Cl. 6 – governance	Governance expectations for PIMS certification bodies	Certification body accreditation status for PIMS

Cl. 5 – impartiality Strengthened impartiality expectations for PIMS certification

WHAT THE CLAUSE REQUIRES

27706 strengthens impartiality, independence, and governance expectations for bodies conducting PIMS audits, over and above the requirements already imposed by ISO/IEC 17021-1. The general prohibition on a certification body providing management system consultancy to an organization it certifies applies, together with the constraints on individuals moving between consultancy or internal auditing and certification work.

WHY IT EXISTS

The privacy market has a structural feature that makes this pressing: many firms offer privacy consultancy, data protection officer services, privacy assessments, and certification, and the same organizations often supply several of these. An organization that engaged a firm for privacy consultancy and then approached the same firm for PIMS certification is in a more common situation than the equivalent in information security, and the constraint bites more often.

WHAT THIS MEANS FOR YOU

1. Disclose all privacy advisory relationships to the certification body, including DPO services and privacy assessments.
2. Check whether your certification body has a related entity providing privacy consultancy, since group relationships create threats too.
3. Expect individuals who advised you to be excluded from your audit team for a period.
4. Be cautious of any provider offering privacy consultancy and accredited PIMS certification as a package.

EVIDENCE TO COLLECT

- Your privacy advisory supplier relationships including group structures
- Disclosures made to the certification body
- The body's impartiality statement and declared relationships

HOW TO DOCUMENT IT

Record any overlap between privacy advisers and PIMS certifiers, at both individual and corporate group level. This is the exposure most likely to invalidate a PIMS certificate after the fact, and it is more common in the privacy market than elsewhere.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the firm that provided privacy consultancy and outsourced data protection officer services also conducted the PIMS certification audit through a related entity, creating an impartiality threat that places the certificate at risk.

Cl. 5 – outsourced DPO Where your certification body also supplies privacy services**WHAT THE CLAUSE REQUIRES**

The impartiality requirements apply to the whole relationship between the certification body, its related entities, and your organization. Where a body or a related entity supplies privacy services that amount to designing, implementing, or maintaining part of your PIMS, that is management system consultancy and the certification body cannot then certify the system it helped build.

WHY IT EXISTS

Privacy services blur into consultancy more easily than most. An outsourced data protection officer, a privacy impact assessment performed for you, or a gap analysis with recommendations all shade toward designing your system. The line is not always obvious in advance, which is why disclosure early is better than discovery late, and why a certification body that accepts such an arrangement without hesitation is a warning rather than a convenience.

WHAT THIS MEANS FOR YOU

1. Map every privacy service you receive and from whom, including through group entities and subcontractors.
2. Ask the certification body directly whether any relationship creates a threat, before contracting.
3. Treat willingness to certify despite an obvious relationship as a reason for caution, not relief.
4. Where you must separate suppliers, do so before certification rather than after a finding.

EVIDENCE TO COLLECT

- Privacy service supplier map including group relationships
- Certification body threat analysis and its conclusion

HOW TO DOCUMENT IT

Record whether the certification body performed and documented a threat analysis of the relationship rather than simply accepting the engagement. The analysis is its obligation and its absence is a signal about how it manages impartiality generally.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the certification body accepted the engagement without any documented analysis of the impartiality threat arising from privacy services supplied by a related entity, indicating that its impartiality management is not operating.

Cl. 5 – confidentiality of PII Confidentiality where the audit evidence is personal data**WHAT THE CLAUSE REQUIRES**

The confidentiality obligations under ISO/IEC 17021-1 apply to information the certification body obtains during certification activities. In a PIMS audit that information frequently includes personally identifiable information itself, since demonstrating conformity may require showing records, rights request handling, incident records, and processing activity detail.

WHY IT EXISTS

This raises a question that does not arise in most certification audits: what is the lawful basis for exposing personal data to your auditor, and does your own privacy notice contemplate it? The certification body's confidentiality obligation protects the information once disclosed, but it does not by itself make the disclosure lawful. This is your obligation, not the body's, and it is easy to overlook while preparing evidence.

WHAT THIS MEANS FOR YOU

1. Consider whether audit evidence can be provided in redacted or pseudonymised form without weakening it.
2. Establish your own basis for disclosing personally identifiable information to the audit team.
3. Confirm confidentiality obligations extend to external auditors and technical experts attending.
4. Where live personal data must be shown, control the circumstances rather than handing over extracts.

EVIDENCE TO COLLECT

- Evidence provision approach with redaction or minimisation where possible
- Your basis for disclosure to the certification body
- Confidentiality coverage for all attending personnel

HOW TO DOCUMENT IT

Record how personally identifiable information was exposed during the audit and on what basis. An organization certifying its privacy management while disclosing personal data to auditors without consideration has a visible inconsistency.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personally identifiable information was provided to the audit team in unredacted form without any assessment of the basis for that disclosure, which is inconsistent with the privacy management the organization is seeking certification for.

Cl. 6 – governance Governance expectations for PIMS certification bodies**WHAT THE CLAUSE REQUIRES**

27706 strengthens governance expectations for bodies conducting PIMS audits, building on the structural requirements in ISO/IEC 17021-1 including the mechanism for safeguarding impartiality with a balance of interests. These are internal to the certification body and assessed by its accreditation body rather than by you.

WHY IT EXISTS

This is context rather than something you act on, but it explains why accredited PIMS certification is worth more than an unaccredited privacy certificate or a proprietary privacy seal. The governance structures, and the accreditation assessment of them, are what make the certificate mean anything to a customer who was not present at the audit.

WHAT THIS MEANS FOR YOU

1. Recognise this as part of what distinguishes accredited PIMS certification from privacy seals and marks.
2. Where you believe a body is behaving commercially rather than impartially at an institutional level, the accreditation body is the route.
3. Confirm accreditation rather than relying on a body's own claims about its governance.

EVIDENCE TO COLLECT

- Certification body accreditation status for PIMS
- The accreditation body's contact route

HOW TO DOCUMENT IT

Record the accreditation body overseeing your certification body and how to reach it. This is the escalation route of last resort and most certified organizations do not know it exists.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization holds a privacy certification from a body that is not accredited for PIMS certification, so none of the governance structures that make such a certificate credible have been independently assessed.

Scope and Audit Duration: Clause 9

Four entries on the scope determination and audit duration criteria 27706 tailors to the controller and processor roles.

Two assumptions carried over from the previous edition cause most of the trouble. The first is drawing PIMS scope by copying the ISMS scope. Because ISO/IEC 27701:2025 is standalone, PIMS scope is established in its own right, and a copied scope will usually be wrong in both directions: including functions that process no personally identifiable information, and excluding processing that sits outside the ISMS boundary. The second is budgeting PIMS audit time as a small increment on ISMS time. Under standalone duration criteria that assumption does not hold, and the figure can be materially larger.

Test your scope statement by asking whether a customer could use it to determine if their data is covered. If answering requires a conversation with your sales team, the scope is not doing its job. And where you operate across jurisdictions, check that site sampling accounts for legal variation rather than only operational similarity – a sample representative of your sites can miss the most demanding applicable regime entirely.

Quick reference: Scope and Duration

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [cyb](#) or [ai](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
Cl. 9 – scope criteria cyb	Scope determination criteria for a PIMS	Agreed PIMS scope statement
Cl. 9 – audit time cyb	Audit duration criteria for a PIMS	Audit time determination for the PIMS with justification
Cl. 9 – combined audits cyb	Combining PIMS certification with other management systems	Combined audit plan showing coverage per standard
Cl. 9 – multi-jurisdiction cyb	Multi-site and multi-jurisdiction PIMS certification	Site and jurisdiction map for processing in scope

Cl. 9 – scope criteria Scope determination criteria for a PIMS

WHAT THE CLAUSE REQUIRES

27706 supplies scope determination criteria tailored to the controller and processor roles. The certification body applies these when reviewing your application and agreeing what will be certified. Scope must reflect the processing of personally identifiable information that the PIMS covers, the roles in which the organization acts, and the boundaries within which conformity is being claimed.

WHY IT EXISTS

Scope is the part of a certificate customers read and the part organizations most often get wrong. For a PIMS the stakes are higher than for an ISMS, because a customer reading a privacy certificate is usually trying to answer a specific question: is the processing of my data covered? A scope statement that does not let them answer that has failed at its purpose regardless of how rigorous the audit was.

WHAT THIS MEANS FOR YOU

1. Draft the scope so a customer can determine whether their processing is covered, not merely so it is technically accurate.
2. State the roles covered, since controller and processor obligations differ and customers care which applies.
3. Resolve scope disagreements before contracting, since changing scope later requires a scope extension process.
4. Check the scope against the processing your contracts commit you to having certified.

EVIDENCE TO COLLECT

- Agreed PIMS scope statement
- Processing activity inventory against the scope
- Customer and contractual requirements for comparison

HOW TO DOCUMENT IT

Test the scope statement by asking whether a customer could use it to determine if their data is covered. If the answer requires a conversation with your sales team, the scope statement is not doing its job.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the PIMS scope statement does not allow a customer to determine whether processing of their personally identifiable information is covered, so the certificate cannot serve the assurance purpose it was obtained for.

Cl. 9 – audit time Audit duration criteria for a PIMS**WHAT THE CLAUSE REQUIRES**

27706 provides audit duration criteria tailored to the controller and processor roles. As under ISO/IEC 17021-1, the certification body determines audit time from the characteristics of the organization and must record justification where the determination departs from the norm. For a PIMS the determinants include the roles in scope, the nature and volume of processing, the jurisdictions involved, and the complexity of the processing arrangements.

WHY IT EXISTS

Organizations transitioning from an integrated PIMS-and-ISMS arrangement often expect PIMS audit time to be a small increment on their ISMS time. Under a standalone PIMS with its own scope and its own duration criteria, that assumption does not hold, and the figure can be materially larger than budgeted. Discovering this at contract stage is better than discovering it during planning.

WHAT THIS MEANS FOR YOU

1. Budget for PIMS audit time determined on its own criteria rather than as an increment to ISMS time.
2. Expect dual-role organizations to attract more audit time than single-role ones.
3. Where you believe the determination is disproportionate, ask for the recorded justification.
4. Remember audit time is accreditation-checked and is not a commercial variable your body can trade away.

EVIDENCE TO COLLECT

- Audit time determination for the PIMS with justification
- Roles and processing characteristics on which it was based

HOW TO DOCUMENT IT

Record whether the data underpinning the audit time determination remains accurate. Processing volumes, jurisdictions, and roles change, and a determination based on stale data no longer matches the organization.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has materially expanded its processing and entered additional jurisdictions since its PIMS audit time was determined, without notifying the certification body, so the audit programme no longer matches the organization it covers.

Cl. 9 – combined audits Combining PIMS certification with other management systems**WHAT THE CLAUSE REQUIRES**

Where an organization holds or seeks certification for more than one management system, audits may be combined or integrated, subject to the requirements applicable to each. Because ISO/IEC 27701:2025 is standalone and follows the common Clauses 4 to 10 structure shared with ISO/IEC 27001 and ISO/IEC 42001, combining is structurally easier than under the previous edition, but each certification retains its own scope, duration determination, and competence requirements.

WHY IT EXISTS

Combination saves time on the shared management system clauses and on shared evidence, which is real value. What it does not do is reduce the PIMS-specific assessment, and organizations sometimes expect a larger discount than is available. The competence requirement is also a constraint: a combined audit needs a team competent across every standard in the combination.

WHAT THIS MEANS FOR YOU

1. Where combining, confirm the team holds competence for every standard involved rather than for the largest one.
2. Expect savings on shared clauses and shared evidence, not on the privacy-specific assessment.
3. Keep scopes distinct even where audits are combined, since the certificates remain separate.
4. Check that a combined audit does not compress the privacy assessment to fit a familiar duration.

EVIDENCE TO COLLECT

- Combined audit plan showing coverage per standard
- Team competence across all standards in the combination
- Separate scope statements per certification

HOW TO DOCUMENT IT

Record whether a combined audit allocated adequate time to the PIMS-specific requirements or whether the privacy assessment was compressed into a schedule built around the ISMS.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the combined audit allocated the majority of its time to information security management, with privacy-specific requirements assessed in a compressed session, so PIMS conformity was not examined to the depth the duration criteria require.

Cl. 9 – multi-jurisdiction Multi-site and multi-jurisdiction PIMS certification

WHAT THE CLAUSE REQUIRES

Where a PIMS covers multiple sites, the sampling provisions of ISO/IEC 17021-1 apply, with the certification body justifying its sample and including the central function. For a PIMS an additional dimension applies: processing may be subject to different legal regimes at different locations, and the applicable law depends on the origin of the personally identifiable information as well as on where processing occurs.

WHY IT EXISTS

Site sampling is a familiar concept; jurisdictional variation is not, and the two do not align. A sample that is representative of your sites may miss a jurisdiction entirely, and a site that looks minor operationally may carry the processing subject to the most demanding regime. The sample needs to account for legal variation, not only for operational similarity.

WHAT THIS MEANS FOR YOU

1. Identify the legal regimes applicable across your processing, not only your site list.
2. Check whether the sampling approach accounts for jurisdictional variation as well as site similarity.
3. Cover unsampled sites and jurisdictions through your own internal audit, since the external sample will not reach them.
4. Expect the central function to be audited every time.

EVIDENCE TO COLLECT

- Site and jurisdiction map for processing in scope
- Sampling rationale and its treatment of legal variation
- Internal audit coverage of unsampled locations

HOW TO DOCUMENT IT

Record whether the sampling approach considered jurisdictional variation. A sample drawn on operational grounds alone may leave the most demanding legal regime in scope entirely unexamined.

EXECUTIVE SUMMARY TREATMENT

Suggested language: site sampling was determined on operational similarity without regard to jurisdiction, leaving processing subject to the most demanding applicable regime unexamined across the certification cycle.

CHAPTER 5

Conducting the PIMS Audit: Clause 9

Seven entries on the audit itself, including the three structured evaluations 27706 requires: privacy risk management, leadership, and performance monitoring.

The privacy risk evaluation is the one most likely to expose an organization that built its PIMS on an existing information security risk process. Security risk is assessed from the organization's perspective: what harm would a breach do to us. Privacy risk includes harm to the individual, which may be substantial even where organizational impact is negligible. A risk register counting only organizational impact has not assessed privacy risk at all, and that single distinction separates a genuine PIMS from an ISMS with privacy labelling.

For stage 2, the exposed area is usually individual rights. An organization can document a rights process thoroughly and be unable to evidence that requests were answered within time, which is the outcome the process exists to produce. Prepare outcome evidence rather than process evidence.

On maintaining certification: privacy scope drifts faster than most. A new customer in a new jurisdiction, a new sub-processor, or a shift from processing on instruction to determining purposes each changes what should be certified, and none feels like a certification event at the time. Add all of them to your notification triggers.

Quick reference: Conducting the Audit

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [cyb](#) or [ai](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
Cl. 9 – privacy risk cyb	Structured evaluation of privacy risk management	Privacy risk assessment methodology and outputs
Cl. 9 – leadership cyb	Structured evaluation of leadership	Privacy policy with evidence of top management ownership
Cl. 9 – performance cyb	Structured evaluation of performance monitoring	Performance measures and data across the period
Cl. 9 – stage 1 cyb	Stage 1 in a PIMS context	Processing activity inventory with roles and legal regimes
Cl. 9 – stage 2 cyb	Stage 2 in a PIMS context	Rights request records with timeliness data
Cl. 9 – certificate cyb	What your PIMS certificate must convey	PIMS certificate with scope, roles, and standard edition
Cl. 9 – maintaining cyb	Surveillance, change, and maintaining PIMS certification	Notifications made to the certification body with dates

Cl. 9 – privacy risk Structured evaluation of privacy risk management

WHAT THE CLAUSE REQUIRES

27706 requires structured evaluation of privacy risk management during PIMS assessments. This is an addition over the technical specification it replaced, and it means the certification body must assess how the organization identifies, evaluates, and treats risks to personally identifiable information and to the individuals it relates to, rather than treating privacy risk as a subset of information security risk.

WHY IT EXISTS

This is the requirement most likely to expose organizations that built their PIMS on an existing information security risk process. Security risk is assessed from the organization's perspective: what harm would a breach do to us. Privacy risk includes harm to the individual, which may be substantial even where organizational impact is negligible. A risk register that only counts organizational impact does not assess privacy risk at all.

WHAT THIS MEANS FOR YOU

1. Check whether your risk assessment considers harm to individuals distinctly from harm to the organization.
2. Expect the audit to test this specifically, since structured evaluation of it is now required.
3. Verify privacy risks are identified from processing characteristics rather than inherited from the security risk register.
4. Confirm risk treatment addresses the individual's exposure, not only the organization's.

EVIDENCE TO COLLECT

- Privacy risk assessment methodology and outputs
- Evidence that harm to individuals is assessed
- Risk treatment decisions and their basis

HOW TO DOCUMENT IT

Record whether privacy risk is assessed from the individual's perspective or only the organization's. This single distinction separates a genuine PIMS from an ISMS with privacy labelling, and it is now subject to structured evaluation.

EXECUTIVE SUMMARY TREATMENT

Suggested language: privacy risk is assessed solely in terms of organizational impact, with no consideration of harm to the individuals whose personally identifiable information is processed, so the privacy risk management the standard requires is not being performed.

Cl. 9 – leadership Structured evaluation of leadership**WHAT THE CLAUSE REQUIRES**

27706 requires structured evaluation of leadership during PIMS assessments. Under the Clauses 4 to 10 structure that ISO/IEC 27701:2025 shares with other management system standards, leadership covers top management commitment, the privacy policy, and the assignment of roles, responsibilities, and authorities for the PIMS.

WHY IT EXISTS

Leadership requirements are present in every management system standard and are frequently audited superficially, through a signed policy and an attendance record at a management review. Requiring structured evaluation raises the bar: the assessment has to establish that leadership is actually engaged with privacy, which is a different question from whether the documentary artefacts exist.

WHAT THIS MEANS FOR YOU

1. Expect top management to be interviewed and to need to speak credibly about privacy risk and objectives.
2. Ensure the privacy policy reflects actual organizational intent rather than a template.
3. Verify roles and authorities for the PIMS are assigned to named individuals who know they hold them.
4. Prepare evidence that leadership decisions have been influenced by privacy considerations.

EVIDENCE TO COLLECT

- Privacy policy with evidence of top management ownership
- Role and authority assignments for the PIMS
- Management review records showing privacy engagement
- Decisions where privacy considerations changed the outcome

HOW TO DOCUMENT IT

Record whether top management can speak to privacy risk without preparation. Leadership requirements are assessed by conversation as much as by document, and structured evaluation makes that conversation harder to avoid.

EXECUTIVE SUMMARY TREATMENT

Suggested language: top management could not describe the organization's principal privacy risks or objectives, and no decision during the period was influenced by privacy considerations, so the leadership engagement the standard requires is documentary rather than actual.

Cl. 9 – performance Structured evaluation of performance monitoring

WHAT THE CLAUSE REQUIRES

27706 requires structured evaluation of performance monitoring during PIMS assessments. This covers how the organization monitors, measures, analyses, and evaluates the performance and effectiveness of its PIMS, including internal audit and management review, under the common management system structure.

WHY IT EXISTS

Performance monitoring is where a management system either demonstrates effect or does not. For a PIMS the useful measures are frequently operational rather than compliance-shaped: rights request response times, incident volumes and causes, the outcome of privacy impact assessments, and the rate at which processing changes trigger assessment. An organization measuring only whether documents were reviewed on schedule is monitoring its paperwork.

WHAT THIS MEANS FOR YOU

1. Establish measures that reflect privacy outcomes rather than document maintenance.
2. Prepare evidence that monitoring has identified problems and that problems produced change.
3. Ensure internal audit covers privacy-specific requirements, not only shared management system clauses.
4. Verify management review addresses privacy performance substantively.

EVIDENCE TO COLLECT

- Performance measures and data across the period
- Internal audit coverage of privacy-specific requirements
- Management review outputs and resulting decisions
- Evidence of change resulting from monitoring

HOW TO DOCUMENT IT

Record whether monitoring measures privacy outcomes or documentary compliance, and whether it has produced any change. Monitoring that never identifies a problem is not functioning.

EXECUTIVE SUMMARY TREATMENT

Suggested language: PIMS performance monitoring tracks document review completion rather than privacy outcomes, and has identified no issues across the period despite recorded rights request delays, indicating the monitoring is not capable of detecting problems.

Cl. 9 – stage 1 Stage 1 in a PIMS context

WHAT THE CLAUSE REQUIRES

Stage 1 evaluates readiness for stage 2, as under ISO/IEC 17021-1. For a PIMS the readiness questions are privacy-specific: whether processing activities and roles are properly identified, whether the scope is coherent, whether privacy risk assessment has been performed, and whether internal audit and management review have covered the PIMS rather than only an underlying ISMS.

WHY IT EXISTS

The commonest PIMS readiness failure is an organization that has documented a privacy management system without having established the factual basis it rests on: what personally identifiable information it holds, where, for what purpose, in which role, and under which legal regime. Without that, the PIMS documents a system that does not correspond to the organization, and stage 2 will find it.

WHAT THIS MEANS FOR YOU

1. Have a complete and accurate processing inventory before stage 1, since everything else depends on it.
2. Ensure role determinations are made and documented across all processing in scope.
3. Complete privacy-specific internal audit and management review, not only ISMS equivalents.
4. Treat a negative stage 1 as a reason to delay rather than to push on.

EVIDENCE TO COLLECT

- Processing activity inventory with roles and legal regimes
- Privacy risk assessment
- PIMS internal audit and management review records
- Stage 1 report and readiness conclusion

HOW TO DOCUMENT IT

Record whether the processing inventory is complete and independently verifiable. This is the foundation of a PIMS, and an inventory assembled from departmental self-declaration is usually incomplete in ways stage 2 will surface.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the processing activity inventory underpinning the PIMS was assembled by self-declaration and omits a stated number of processing activities identified during review, so the PIMS documents a system narrower than the organization's actual processing.

Cl. 9 – stage 2 Stage 2 in a PIMS context

WHAT THE CLAUSE REQUIRES

Stage 2 evaluates implementation and effectiveness at your site. For a PIMS this includes the structured evaluations 27706 requires of privacy risk management, leadership, and performance monitoring, together with assessment of conformity against the ISO/IEC 27701 requirements and the annexed controls applicable to the roles in scope.

WHY IT EXISTS

Effectiveness is the operative word, and for a PIMS it means the system produces privacy outcomes rather than privacy documents. The most exposed area is usually individual rights: an organization can document a rights process thoroughly and be unable to evidence that requests were actually answered within time, which is the outcome the process exists to produce.

WHAT THIS MEANS FOR YOU

1. Prepare outcome evidence: rights requests handled and their timeliness, incidents and their handling, assessments performed and their effect.
2. Ensure operational staff can describe privacy obligations relevant to their work.
3. Have evidence for the annexed controls applicable to your roles, and know which apply.
4. Expect legal conformity to be examined as part of effectiveness, not treated as out of scope.

EVIDENCE TO COLLECT

- Rights request records with timeliness data
- Privacy incident records and outcomes
- Control evidence for the roles in scope
- Evidence of privacy assessment influencing decisions

HOW TO DOCUMENT IT

Record whether the organization can evidence privacy outcomes or only privacy processes. Documentation without evidence of effect is the characteristic PIMS stage 2 failure.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the PIMS is fully documented but the organization cannot evidence that individual rights requests were answered within applicable time limits, so effectiveness cannot be demonstrated for the process most visible to the individuals the system exists to protect.

Cl. 9 – certificate What your PIMS certificate must convey**WHAT THE CLAUSE REQUIRES**

Certification documents must identify the certification body, your organization, the scope, the effective date, and the standard certified against, as required by ISO/IEC 17021-1. For a PIMS the scope statement carries additional weight because it must convey the roles covered and the processing to which certification applies.

WHY IT EXISTS

A PIMS certificate is read by customers deciding whether to entrust you with personal data, and by their own compliance functions assessing you as a supplier. A scope statement that says less than they need produces follow-up questionnaires, which is the cost certification was supposed to remove. One that overstates coverage produces a worse problem when the gap is discovered.

WHAT THIS MEANS FOR YOU

1. Read the scope statement as a customer's privacy team would, and check it answers their question.
2. Confirm roles covered are stated, since controller and processor obligations differ materially.
3. Verify the edition of ISO/IEC 27701 cited is the one your customers require.
4. Ensure marketing claims do not exceed the certificate scope.

EVIDENCE TO COLLECT

- PIMS certificate with scope, roles, and standard edition
- Customer supplier assurance requirements for comparison
- Marketing and tender claims about certification

HOW TO DOCUMENT IT

Compare the certificate against the supplier assurance questionnaires you actually receive. If the certificate does not answer the questions customers keep asking, the scope was drawn without reference to its purpose.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the PIMS certificate does not state the roles covered or identify the processing in scope, so customers continue to issue supplier assurance questionnaires that the certificate was obtained to displace.

Cl. 9 – maintaining Surveillance, change, and maintaining PIMS certification**WHAT THE CLAUSE REQUIRES**

Surveillance and recertification operate as under ISO/IEC 17021-1, with surveillance at least annually and recertification completed before expiry. For a PIMS the notification obligation carries particular weight: changes to processing, to roles, to jurisdictions, and to sub-processing arrangements all bear on whether the certified system still describes the organization.

WHY IT EXISTS

Privacy scope moves faster than most. A new customer in a new jurisdiction, a new sub-processor, or a change from processing on instruction to determining purposes can each alter what should be certified, and none of them feels like a certification event when it happens. An organization whose processing has moved substantially since certification holds a certificate describing something it no longer is.

WHAT THIS MEANS FOR YOU

1. Add processing change, new jurisdictions, role changes, and sub-processor changes to your notification triggers.
2. Review at each surveillance whether the scope statement still describes your processing accurately.
3. Book recertification with enough margin to resolve a major nonconformity before expiry.
4. Cover unsampled sites and jurisdictions through internal audit between external visits.

EVIDENCE TO COLLECT

- Notifications made to the certification body with dates
- Processing change records for comparison
- Scope review at each surveillance
- Recertification date against certificate expiry

HOW TO DOCUMENT IT

Compare notifications made against your own record of processing, role, and jurisdiction changes. Undisclosed change is a breach of the certification agreement independent of any PIMS nonconformity, and privacy scope drifts faster than organizations expect.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization entered additional jurisdictions and engaged new sub-processors during the certification cycle without notifying its certification body, so the certificate describes a scope of processing that no longer reflects the organization.

Glossary

Terms are listed alphabetically. Each is also indexed at the point of first use.

Accreditation

Third-party attestation that a certification body is competent for specific certification tasks. Accreditation for ISMS certification does not extend to PIMS certification; check the scope covers PIMS specifically.

Combined audit

An audit of two or more management systems together. Structurally easier since ISO/IEC 27701:2025 adopted the common Clauses 4 to 10 structure, but each certification keeps its own scope, duration determination, and competence requirements.

Controller

The party determining the purposes and means of processing personally identifiable information. One of the two roles around which 27706 tailors its scope and duration criteria.

Data protection officer

A privacy role that, when outsourced to a firm that also certifies, can constitute management system consultancy and create an impartiality threat.

Impartiality

Actual and perceived objectivity. 27706 strengthens expectations over ISO/IEC 17021-1 because the privacy market frequently sees advisory and certification services offered by the same groups.

ISO/IEC 17021-1

The general requirements for bodies providing audit and certification of management systems. 27706 operates in addition to it, not instead of it. Its clause structure is the one 27706 aligns to.

ISO/IEC 27701

The standard your PIMS is implemented against and certified to. The 2025 edition is standalone, with no ISO/IEC 27001 prerequisite, following the common Clauses 4 to 10 structure.

ISO/IEC TS 27006-2:2021

The technical specification 27706 replaced. 27706 is a full International Standard, aligns its clause structure to ISO/IEC 17021-1 rather than ISO/IEC 27006-1, and adds annexed guidance.

PII

Personally identifiable information. The subject matter a PIMS manages, and frequently also the audit evidence, which raises a disclosure question most certification audits do not.

PIMS

Privacy information management system. What is certified under ISO/IEC 27701.

PIMS scope

The processing, roles, and boundaries the certification covers. Determined in its own right under the 2025 standalone edition, and not derivable by copying an ISMS scope.

Privacy risk

Risk to personally identifiable information and to the individuals it relates to. Subject to structured evaluation under 27706. Distinct from security risk because it counts harm to the individual, not only to the organization.

Processor

The party processing personally identifiable information on a controller's behalf. Assessment turns substantially on staying within instructions and managing the sub-processing chain.

Role determination

Establishing whether the organization acts as controller, processor, or both for processing in scope. Follows the factual reality of who decides purposes and means, not the contractual label. Drives scope, audit time, and competence requirements.

Scope statement

The text on the certificate defining what is covered. For a PIMS it must convey the roles and the processing, because a customer reads it to answer one question: is my data covered?

Structured evaluation

The requirement 27706 adds for assessment of privacy risk management, leadership, and performance monitoring during PIMS assessments.

Sub-processor

A party engaged by a processor to carry out processing. Changes to the sub-processing chain are notifiable, and the chain is a focus of processor-role assessment.

Technical expert

A person providing specific knowledge on the subject audited. Accompanies the team rather than auditing independently. 27706 defines competence requirements for them, and confidentiality coverage matters because they will see personally identifiable information.

Transition

Two run concurrently: your PIMS to ISO/IEC 27701:2025, and your certification body to ISO/IEC 27706. Accreditation bodies have published arrangements. Check both timelines align.

Workpaper

The assessor's record of what was tested, how, what was found, and what was concluded.

Index of Terms and Concepts

- Accreditation, [32](#)
- Audit duration criteria for a PIMS, [21](#)
- Combined audit, [32](#)
- Combining PIMS certification with other management systems, [22](#)
- Competence for the controller and processor roles, [11](#)
- Competence of certification decision-makers, [13](#)
- Confidentiality where the audit evidence is personal data, [17](#)
- Controller, [32](#)
- Controller and processor: the distinction that organizes everything, [5](#)
- Data protection officer, [32](#)
- Determining PIMS scope, and how it relates to any ISMS scope, [6](#)
- Governance expectations for PIMS certification bodies, [18](#)
- Impartiality, [32](#)
- ISO/IEC 17021-1, [32](#)
- ISO/IEC 27701, [32](#)
- ISO/IEC TS 27006-2:2021, [32](#)
- Knowledge of privacy law and regulation, [10](#)
- Multi-site and multi-jurisdiction PIMS certification, [23](#)
- PII, [32](#)
- PIMS, [32](#)
- PIMS scope, [32](#)
- Privacy risk, [33](#)
- Processor, [33](#)
- Role determination, [33](#)
- Scope determination criteria for a PIMS, [20](#)
- Scope statement, [33](#)
- Stage 1 in a PIMS context, [28](#)
- Stage 2 in a PIMS context, [29](#)
- Strengthened impartiality expectations for PIMS certification, [15](#)
- Structured evaluation, [33](#)
- Structured evaluation of leadership, [26](#)
- Structured evaluation of performance monitoring, [27](#)
- Structured evaluation of privacy risk management, [25](#)
- Sub-processor, [33](#)
- Surveillance, change, and maintaining PIMS certification, [31](#)
- Technical expert, [33](#)
- Technical experts in a privacy context, [12](#)
- The competence framework for PIMS certification, [9](#)
- The transition from ISO/IEC TS 27006-2:2021, [7](#)
- Transition, [33](#)
- What carries over from ISO/IEC 17021-1, [3](#)
- What is actually being certified: the PIMS under ISO/IEC 27701, [4](#)
- What ISO/IEC 27706 is, and what it sits on top of, [2](#)
- What your PIMS certificate must convey, [30](#)
- Where your certification body also supplies privacy services, [16](#)
- Workpaper, [33](#)